CIS LINUX AUDIT · VERSIÓN 1.0.0

Modelo de Resultados y Cumplimiento

Estados, resultado CIS técnico frente a resultado final e indicadores con sus fórmulas.

Versión 1.0.0 | Fecha 2026-11-10 | Versión operativa | Auditoría de solo lectura

Contenido

1. Dos resultados por control
2. Estados
3. Tipos de cumplimiento
4. Indicadores
5. Ejemplo de cálculo
6. Exclusiones en el resultado
7. Pendientes y su tratamiento

1. Dos resultados por control

Cada fila en alcance (fila del Excel con propuesta **YES**, por host) produce dos resultados independientes:

Resultado	Campo	Qué considera
Resultado CIS técnico	resultado_cis	Solo el requisito del CIS Benchmark oficial y la evidencia del servidor.
Resultado final	resultado_final + tipo_cumplimiento	El técnico más las exclusiones de Infraestructura y las omisiones por proceso independiente.

- La capa final se aplica **después** de la evaluación técnica y nunca sobrescribe ni oculta el hallazgo CIS.
- **Sin excepción**: Resultado CIS técnico = Resultado final.
- **Con excepción que cubre todo**: técnico NO CUMPLE → final CUMPLE, tipo EXCLUSION_INFRAESTRUCTURA.
- **Con excepción que no cubre todo**: final NO CUMPLE con la lista de hallazgos no cubiertos.
- **Parchado**: técnico según evidencia → final CONTROL EXCLUIDO, tipo CONTROL_EXCLUIDO_PROCESO_INDEPENDIENTE.
- **Exclusión P1 de control completo** (CONTROL_NO_APLICADO): final CONTROL EXCLUIDO, tipo CONTROL_EXCLUIDO_INFRAESTRUCTURA.

2. Estados

Estado	Significado	¿Concluye?
CUMPLE	Evidencia suficiente de que el requisito está implementado.	Sí
NO CUMPLE	Evidencia objetiva de que al menos un requisito obligatorio no se cumple.	Sí
CUMPLE PARCIALMENTE	Requisitos independientes de una misma fila: unos cumplen y otros no (desviación parcial).	Sí
NO APLICA	El requisito no aplica al host, con causa explícita permitida por el CIS (p. ej. método de logging).	Sí
CONTROL EXCLUIDO	Solo resultado final: proceso formal independiente (parchado) o exclusión de Infraestructura de control completo.	Sí (decisión formal)
REQUIERE EVIDENCIA ORGANIZACIONAL	La evidencia técnica existe, pero la conclusión depende de una lista o aprobación externa.	No
REQUIERE VALIDACIÓN MANUAL	No puede concluirse de forma segura o automática (p. ej. filesystem profundo pendiente).	No
ERROR DE AUDITORÍA	Problema del proceso (conexión, permisos, recolector, timeout, salida no interpretable).	No

Reglas

- Ningún control es CUMPLE sin evidencia.
- ERROR DE AUDITORÍA nunca se convierte en NO CUMPLE.
- CONTROL EXCLUIDO y OMITIDO nunca se convierten en CUMPLE.
- REQUIERE REMEDIACIÓN MANUAL y REQUIERE AJUSTE MANUAL conservan el NO CUMPLE técnico y cuentan como no cumplidos.
- NO APLICA siempre muestra su causa.

FUERA DE ALCANCE (propuesta del proveedor NO) se conserva para trazabilidad, pero no forma parte del universo de ningún indicador. Los **prerrequisitos internos** (PRE-*) se informan en un bloque propio y no entran en ningún indicador CIS.

3. Tipos de cumplimiento

tipo_cumplimiento	Cuándo
CUMPLIMIENTO_CIS	Cumple el CIS sin necesitar exclusiones.
INCUMPLIMIENTO_CIS	No cumple y no hay exclusión que cubra todos los hallazgos.
CUMPLIMIENTO_PARCIAL_CIS	Desviación parcial.
EXCLUSION_INFRAESTRUCTURA	Todos los hallazgos están cubiertos por una exclusión definida en el Excel.
INSTRUMENTACION_AUDITORIA	El único hallazgo es la regla temporal de auditoría de srvinnops, verificada byte a byte.
CONTROL_EXCLUIDO_PROCESO_INDEPENDIENTE	Control gestionado por el proceso formal de parchado.
CONTROL_OMITIDO_INFRAESTRUCTURA	OMITIDO: fila P1 con TIPO CONTROL_NO_APLICADO (solo rds y tipc).
REQUIERE_REMEDIACION_MANUAL	Incumplimiento técnico que requiere intervención especializada (Ensure no unconfined services exist).
REQUIERE_AJUSTE_MANUAL	Incumplimiento técnico con ajuste operativo pendiente (7.2.9: solo modos de archivos ocultos más permisivos).
NO_APLICA / NO_APLICA_METODO_LOGGING	No aplica (causa técnica / método de logging corporativo).
SIN_CONCLUSION	Validación manual, evidencia organizacional o error de auditoría.

4. Indicadores

Cuatro indicadores independientes. Unidad: fila del Excel con propuesta YES, por host. Nunca se mezclan sus numeradores ni sus denominadores.

1. Cumplimiento CIS técnico

```
% cumplimiento CIS técnico = CUMPLE / (CUMPLE + NO CUMPLE + CUMPLE PARCIALMENTE) × 100
(sobre resultado_cis)
```

- Fuera del denominador (informados aparte): NO APLICA, ERROR DE AUDITORÍA, REQUIERE VALIDACIÓN MANUAL, REQUIERE EVIDENCIA ORGANIZACIONAL y conflictos de línea base.
- No lo afectan las exclusiones, la instrumentación de auditoría ni los controles excluidos: un CONTROL EXCLUIDO conserva su resultado técnico.

2. Cobertura técnica CIS

```
% cobertura técnica CIS = (CUMPLE + NO CUMPLE + CUMPLE PARCIALMENTE) / filas YES × 100
(sobre resultado_cis)
```

Se presenta siempre junto al cumplimiento CIS técnico.

3. Cumplimiento final de línea base

```
% cumplimiento final de línea base = CUMPLE / (CUMPLE + NO CUMPLE + CUMPLE PARCIALMENTE) ×
100     (sobre resultado_final; CONTROL EXCLUIDO fuera)
```

Incluye las exclusiones de Infraestructura. Se etiqueta siempre “Cumplimiento final de línea base”, **nunca** “Cumplimiento CIS”.

4. Cobertura de validación

```
% cobertura de validación = filas concluidas / filas YES × 100
```

Una fila está concluida si su resultado final es CUMPLE, NO CUMPLE, CUMPLE PARCIALMENTE, NO APLICA o CONTROL EXCLUIDO **y** tiene evidencia o motivo trazable. Todas las filas YES permanecen en el denominador. Es el objetivo operativo: 100 % de cobertura de validación (que no significa 100 % de cumplimiento).

5. Ejemplo de cálculo

Ejemplo con 218 filas YES:

Resultado final	Filas
CUMPLE	190
NO CUMPLE	13
NO APLICA	9
CONTROL EXCLUIDO	3
REQUIERE VALIDACIÓN MANUAL	2
REQUIERE EVIDENCIA ORGANIZACIONAL	1
ERROR DE AUDITORÍA	0

- Cumplimiento final de línea base = 190 / (190 + 13) = 93,6 %.
- Cobertura de validación = (190 + 13 + 9 + 3) / 218 = 215 / 218 = 98,6 %.
- El cumplimiento CIS técnico y la cobertura técnica se calculan igual pero sobre resultado_cis (p. ej. 185 / 204 = 90,7 % y 204 / 218 = 93,6 %): las exclusiones y omisiones no los modifican.

6. Exclusiones en el resultado

- P1: la columna 'Exclusiones de Infraestructura' define usuarios autorizados (TIPO USUARIOS) o un control no aplicado (CONTROL_NO_APLICADO).
- P2: la columna 'EXCLUSIONES (Infraestructura Linux)' solo cambia el resultado si define un valor alternativo para un parámetro exigido por el CIS y ese valor se verificó en el host, o si autoriza elementos concretos (ARCHIVOS_LOG_AUTORIZADOS: cada archivo debe coincidir con un patrón y cumplir la CONDICION en la evidencia); el resto se informa como condición adicional.
- El reporte muestra: exclusión definida y aplicada, elementos autorizados, hallazgos encontrados, cubiertos y no cubiertos, motivo, fuente y origen (LINEA_BASE_P1 / LINEA_BASE_P2).
- Si un hallazgo no está identificado por elemento (usuario, archivo), una exclusión por usuarios no puede cubrirlo (fail-closed).

7. Pendientes y su tratamiento

Categoría en el reporte	Origen	Cómo se cierra
EVIDENCIA ORGANIZACIONAL	Lista o aprobación externa no disponible (p. ej. SUID/SGID 7.1.13)	Aprobación formal en config/ listas_aprobadas.yml.
AUTOMATIZACIÓN PENDIENTE	Filesystem profundo no ejecutado, evidencia de una versión anterior del recolector, valor no determinable sin ejecutar código	Ejecución con el recolector vigente / --filesystem-profundo, o validación manual documentada.
CONFLICTO DE BASELINE	La línea base exige requisitos incompatibles	Decisión del responsable de la línea base.
VALIDACIÓN MANUAL	Revisión humana exigida por el propio Benchmark	Revisión documentada.